

RETEST ETHICAL HACKING

Proyecto: scan-upload-t4rfahxj | Fecha: 19/05/2026

Target API: https://urs.qa.vettica.co | Total hallazgos: 8
Crítica: 0 | Alta: 0 | Media: 2 | Baja: 6
Priorización: 8 hallazgos

Colección importada: 16 rutas en total; este informe detalla solo las 1 seleccionadas para el análisis.

Endpoints analizados

#	Metodo	Path	Hallazgos
1	POST	/miniprogram/api/v2/authorization/applyToken	0

#	Vulnerabilidad	Riesgo	CVSS	Estado	Endpoint
1	Falta cabecera Strict-Transport-Security (HSTS)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
2	Rate limiting no evidente (heurístico)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co/miniprogram/api/v2/authorization/a
3	Falta X-Content-Type-Options	LOW	3.0	Persistente	https://urs.qa.vettica.co/
4	Falta Referrer-Policy	LOW	3.0	Persistente	https://urs.qa.vettica.co/
5	Validación manual requerida: BOLA/IDOR por objeto	LOW	3.0	Persistente	https://urs.qa.vettica.co
6	Validación manual requerida: BFLA por rol	LOW	3.0	Persistente	https://urs.qa.vettica.co
7	Validación manual requerida: Mass Assignment	LOW	3.0	Persistente	https://urs.qa.vettica.co
8	Validación manual requerida: JWT claims/TTL/revocación	LOW	3.0	Persistente	https://urs.qa.vettica.co

Detalle tecnico

1. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: https://urs.qa.vettica.co

Descripcion: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendacion: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

2. Rate limiting no evidente (heurístico) (MEDIUM)

Estado: Persistente | CWE: CWE-770

Endpoint: https://urs.qa.vettica.co/miniprogram/api/v2/authorization/applyToken

Descripcion: No se observó 429 ni cabeceras de rate-limit en ráfaga de pruebas hacia https://urs.qa.vettica.co/miniprogram/api/v2/authorization/applyToken.

Recomendacion: Implementa límites por IP/usuario/token y cabeceras de cuota/reintento.

3. Falta X-Content-Type-Options (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: https://urs.qa.vettica.co/

Descripcion: La respuesta no incluye X-Content-Type-Options: nosniff.

Recomendacion: Agrega X-Content-Type-Options: nosniff en API gateway/backend.

4. Falta Referrer-Policy (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: No se encontró cabecera Referrer-Policy en la respuesta del API.

Recomendación: Configura Referrer-Policy estricta (p. ej., no-referrer).

5. Validación manual requerida: BOLA/IDOR por objeto (LOW)

Estado: Persistente | CWE: CWE-639

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Ejecuta pruebas con dos identidades y cruza IDs para detectar acceso indebido a recursos de terceros.

6. Validación manual requerida: BFLA por rol (LOW)

Estado: Persistente | CWE: CWE-285

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Prueba endpoints de privilegio alto con cuentas de menor rol y verifica denegación consistente.

7. Validación manual requerida: Mass Assignment (LOW)

Estado: Persistente | CWE: CWE-915

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Intenta campos no permitidos en payloads (role, status, flags internos) y valida whitelists server-side.

8. Validación manual requerida: JWT claims/TTL/revocación (LOW)

Estado: Persistente | CWE: CWE-613

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Verifica exp/iat/nbf/aud/iss/jti, rotación de claves y revocación de tokens.